

Procedimiento de Respuesta a Incidentes de Seguridad

Roles, matriz de severidades, ciclo de vida, SLAs, comunicaciones y métricas para incidentes que afectan disponibilidad o datos.

Aurora AI Studio S.A.S.

OCTUBRE 2025

1. Objetivo y Alcance

Este documento define el procedimiento formal de respuesta a incidentes de seguridad y operacionales en la plataforma Aurora AI Studio. Su objetivo es minimizar el impacto sobre los usuarios, garantizar la trazabilidad de las acciones tomadas y cumplir con las obligaciones regulatorias aplicables (Ley 1581 de 2012, notificación de brechas a la SIC, RGPD Art. 33-34 cuando aplique). Aplica a todos los incidentes que afecten la disponibilidad, confidencialidad o integridad del servicio, desde degradaciones de rendimiento hasta brechas de datos personales, e involucra a todos los equipos internos (SRE, Seguridad, Producto, Legal, Comunicaciones) y a los usuarios afectados según corresponda.

2. Roles y Responsabilidades

Durante un incidente activo se activan roles específicos con responsabilidades claras para evitar duplicación de esfuerzos y asegurar decisiones rápidas. Los roles se asignan al declarar el incidente y se mantienen hasta el cierre formal. La composición del equipo varía según severidad: SEV-1 y SEV-2 activan el equipo completo; SEV-3 y SEV-4 pueden gestionarse con un subconjunto.

- **Incident Commander (IC):** lidera la respuesta, coordina al equipo, toma decisiones de mitigación y autoriza comunicaciones. Única voz con autoridad para declarar cerrado el incidente.
- **SRE On-Call:** ejecuta la mitigación técnica (rollbacks, escalados, diversiones de tráfico). Mantiene actualizada la línea de tiempo en el canal del incidente.
- **Comms Lead:** redacta y publica actualizaciones en la status page, atiende consultas de usuarios y coordina con el equipo de Soporte los tickets masivos.
- **Security Lead:** evalúa el impacto sobre datos personales, coordina forense y notificaciones regulatorias. Es el responsable de activar el plan de brechas.
- **Legal & DPO:** evalúa obligaciones de notificación a autoridades y titulares; redacta comunicaciones formales; coordina con seguros cibernéticos.

3. Clasificación de Severidades

Toda detección se clasifica al declarar el incidente. La severidad inicial puede ajustarse durante el ciclo de vida a medida que se conoce el impacto real. La siguiente matriz define cada nivel, ejemplos y los SLAs de respuesta y comunicación asociados.

Sev	Definición	Ejemplos	Respuesta	Update
SEV -1	Impacto total o parcial en producción; datos personales comprometidos	Plataforma caída; brecha de datos; ransomware	15 min	30 min
SEV -2	Degradación significativa en producción; sin workaround	API con 30% de errores; latencia >5s; KB principal inaccesible	30 min	1 h
SEV -3	Degradación menor; existe workaround	Latencia elevada en un modelo secundario; feature no crítica caída	2 h	4 h
SEV -4	Cosmético o impacto individual; no afecta producción	Bug en UI; error en doc; consulta de un usuario	1 día hábil	N/A

4. Ciclo de Vida del Incidente

El procedimiento se estructura en cinco fases consecutivas, cada una con objetivos y criterios de salida claros. La fase de detección puede ser automática (alertas de monitoreo) o manual (reporte de usuario). Las fases de contención y erradicación pueden iterarse si la primera mitigación no resuelve el problema. La fase de post-mortem es obligatoria para todo SEV-1 y SEV-2 y recomendada para SEV-3 recurrentes.

4.1 Detección

La detección se origina en (i) alertas automáticas de monitoreo (Datadog, PagerDuty), (ii) reportes de usuarios vía soporte o status page, (iii) hallazgos del equipo de seguridad en revisiones proactivas. Cualquier persona que detecte un incidente debe declararlo inmediatamente en el canal #incidentes de Slack con el comando `/incident declare`, que crea automáticamente el canal de incidente, la página de coordinación y la entrada en la status page interna. El primer respondiente asume el rol de IC de forma interina hasta la designación formal.

4.2 Contención

La contención busca limitar el impacto inmediato sin necesariamente resolver la causa raíz. Acciones típicas incluyen: rollback a la última versión estable, escalado horizontal, división de tráfico, bloqueo de IPs maliciosas, rotación de credenciales comprometidas, deshabilitación de features afectadas. El IC coordina las acciones; el SRE las ejecuta y documenta cada paso con timestamp en el canal del incidente. La prioridad es restaurar el servicio sano antes que entender la causa raíz.

4.3 Erradicación

Una vez contenido, se trabaja en eliminar la causa raíz. Esto puede incluir: aplicar un parche definitivo, depurar código, purgar datos contaminados, revocar y reemitir credenciales masivamente, actualizar configuraciones. Las acciones se prueban primero en staging y se despliegan con feature flags para permitir rollback rápido. El Security Lead evalúa si se requiere análisis forense antes de purgar evidencias.

4.4 Recuperación

La recuperación restablece el servicio a su estado normal y verifica la integridad de los datos. Incluye: reanudar el tráfico completo, validar métricas de SLO, sincronizar bases de datos réplica, rearmar caches, comunicar el restablecimiento a usuarios. El incidente se considera técnicamente resuelto cuando todos los SLO vuelven a verde por al menos 30 minutos consecutivos y el IC lo declara cerrado en el canal.

4.5 Post-Mortem

Dentro de los cinco (5) días hábiles posteriores al cierre, el IC convoca una sesión post-mortem con todos los participantes. La sesión produce un documento siguiendo el formato sin culpa (blameless post-mortem): timeline detallado, impacto en usuarios y métricas, causa raíz (5 whys), factores contribuyentes, lo que funcionó bien, lo que no funcionó, acciones correctivas con responsables y fechas. El documento se publica en el wiki interno y las acciones se trackean en el backlog de SRE.

Plantilla de post-mortem disponible en: wiki.aurora-ai/internal/postmortem-template. Todo post-mortem de SEV-1 debe ser revisado por el CTO antes de cerrar las acciones. Las lecciones aprendidas se incorporan al runbook correspondiente en máximo 30 días.

5. Comunicaciones

La comunicación durante el incidente sigue el principio de transparencia controlada: información veraz, oportuna y proporcionada al impacto. Para SEV-1 y SEV-2 se publica actualización inicial en la status page pública dentro de los primeros 30 minutos, y luego actualizaciones cada hora hasta el cierre. Para SEV-3 se publica si hay impacto visible para usuarios; SEV-4 no requiere publicación. El Comms Lead redacta los mensajes y el IC los aprueba antes de su publicación.

Las notificaciones a autoridades (Superintendencia de Industria y Comercio por brechas de datos personales en Colombia, autoridades de protección de datos en jurisdicciones aplicables) se coordinan con el DPO y se realizan dentro de los plazos legales: 72 horas desde el conocimiento para RGPD, plazo razonable para Ley 1581. La notificación a usuarios afectados se envía cuando exista riesgo relevante para sus derechos, incluyendo: descripción del incidente, datos comprometidos, medidas tomadas, recomendaciones de autoprotección y canal de contacto.

6. Métricas y Mejora Continua

Aurora AI Studio mide la madurez de su respuesta a incidentes con métricas objetivas. Las métricas se revisan mensualmente en el comité de SRE y alimentan el plan de mejora continua. Las metas anuales se publican en el reporte de transparencia.

- **MTTD (Mean Time To Detect):** tiempo medio desde que el incidente inicia hasta que es detectado. Meta: < 5 minutos para SEV-1.
- **MTTA (Mean Time To Acknowledge):** tiempo medio desde la alerta hasta que un respondiente toma el incidente. Meta: < 5 minutos para SEV-1/2.
- **MTTR (Mean Time To Resolve):** tiempo medio desde el inicio hasta el cierre técnico. Meta: < 2 horas para SEV-1; < 4 horas para SEV-2.
- **Tasa de post-mortem completados:** porcentaje de SEV-1/2 con post-mortem publicado dentro del SLA. Meta: 100%.
- **Tasa de acciones cerradas:** porcentaje de acciones correctivas cerradas dentro del plazo comprometido. Meta: > 85%.